

ISO 27001 Audit Report

Annex A Section 8 — Technology Controls

Host: WINDOWS OS: Microsoft Windows 11 Home Collected: 2026-04-01 23:37:47 Report Generated: 2026-04-01T23:37:47

87			
Total Checks			
16			
Passed			
14			
Failed			
18.4%			
Compliance			
Severity	Passed	Failed	Total
HIGH	10	8	18
MEDIUM	6	5	11
LOW	0	1	1

A.8.1 — User Endpoint Devices

ERROR Screen Lock Timeout GPO Configured A.8.1.1

A Group Policy should enforce screen lock after a period of inactivity to prevent unauthorized access to unattended devices.

Severity: HIGH **Expected:** True **Actual:** Error: The term 'Get-GPO' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

ERROR Removable Storage Access Controlled A.8.1.2

GPO should restrict or control access to removable storage devices (USB drives, external HDDs) to prevent data exfiltration.

Severity: **MEDIUM** **Expected:** True **Actual:** Error: The term 'Get-GPO' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

A.8.10 — Information Deletion

ERROR AD Recycle Bin Enabled A.8.10.1

The Active Directory Recycle Bin should be enabled to allow recovery of accidentally deleted AD objects.

Severity: **HIGH** **Expected:** True **Actual:** Error: The term 'Get-ADOptionalFeature' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

ERROR Tombstone Lifetime Adequate A.8.10.2

The tombstone lifetime should be at least 180 days to ensure proper AD replication and object recovery.

Severity: **MEDIUM** **Expected:** 180 **Actual:** Error: The term 'Get-ADRootDSE' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

A.8.11 — Data Masking

ERROR Confidential Attributes Protected A.8.11.1

Sensitive AD attributes should have ACLs restricting who can read them, protecting data like personal information.

Severity: **MEDIUM** **Expected:** **Actual:** Error: The term 'Get-ADRootDSE' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

ERROR Fine-Grained Password Policies Exist A.8.11.2

Fine-Grained Password Policies (FGPP) should be defined for groups requiring stricter controls (admins, service accounts).

Severity: **MEDIUM** **Expected:** 1 **Actual:** Error: The term 'Get-ADFineGrainedPasswordPolicy' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

A.8.12 — Data Leakage Prevention

ERROR USB Storage Restriction GPO Configured A.8.12.1

A GPO should restrict removable storage devices to prevent data exfiltration via USB drives.

Severity: **HIGH** **Expected:** True **Actual:** Error: The term 'Get-GPO' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct

and try again.

ERROR BitLocker Policy Configured A.8.12.2

BitLocker drive encryption should be enforced via GPO to protect data on endpoint devices.

Severity: MEDIUM **Expected:** True **Actual:** Error: The term 'Get-GPO' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

A.8.13 — Information Backup

ERROR AD System State Backup Recent A.8.13.1

Active Directory system state should be backed up regularly. Last backup should be within 30 days.

Severity: HIGH **Expected:** False **Actual:** Error: The term 'repadmin' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

FAIL SYSVOL Replication Healthy A.8.13.2

SYSVOL replication (DFSR or FRS) should be functioning correctly for Group Policy distribution.

Severity: HIGH **Expected:** True **Actual:** False

■ Remediation Steps

1. Check DFSR service: Get-Service DFSR 2. Start DFSR if stopped: Start-Service DFSR 3. Verify SYSVOL replication: dcdiag /test:sysvolcheck /test:netlogons 4. If using FRS, consider migrating to DFSR: dfsrmig /setglobalstate 0 (through all stages)

A.8.14 — Redundancy of Information Processing Facilities

ERROR Multiple Domain Controllers Exist A.8.14.1

At least two Domain Controllers should exist for redundancy and fault tolerance.

Severity: HIGH **Expected:** 2 **Actual:** Error: The term 'Get-ADDomainController' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

ERROR FSMO Roles Distributed A.8.14.2

FSMO (Flexible Single Master Operations) roles should be reviewed to ensure they are on reachable Domain Controllers.

Severity: MEDIUM **Expected:** Actual: Error: The term 'Get-ADForest' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

ERROR AD Sites and Subnets Configured A.8.14.3

AD Sites and Services should have properly configured sites and subnets for optimized replication and client authentication.

Severity: MEDIUM **Expected:** Sites: **Actual:** Error: The term 'Get-ADReplicationSite' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

A.8.15 — Logging

FAIL Audit Policy - Account Logon Events A.8.15.1

Audit policy should log both success and failure for account logon events to track authentication activity.

Severity: HIGH **Expected:** True **Actual:** False

■ Remediation Steps

1. Configure via GPO: Computer Configuration > Policies > Windows Settings > Security Settings > Advanced Audit Policy Configuration > Audit Policies > Account Logon 2. Enable "Audit Credential Validation" for Success and Failure 3. Or via command line: auditpol /set /subcategory:"Credential Validation" /success:enable /failure:enable 4. Run: gpupdate /force

FAIL Audit Policy - Account Management A.8.15.2

User and group account management events should be audited to track privilege changes.

Severity: HIGH **Expected:** True **Actual:** False

■ Remediation Steps

1. Configure via GPO: Advanced Audit Policy Configuration > Account Management 2. Enable "Audit User Account Management" for Success and Failure 3. Also enable "Audit Security Group Management" 4. Run: gpupdate /force

FAIL Audit Policy - Directory Service Access A.8.15.3

Directory Service access should be audited to track AD object access and modifications.

Severity: HIGH **Expected:** True **Actual:** False

■ Remediation Steps

1. Configure via GPO: Advanced Audit Policy Configuration > DS Access 2. Enable "Audit Directory Service Access" for Success and Failure 3. Enable "Audit Directory Service Changes" 4. Configure SACLs on critical AD objects for detailed tracking

PASS Audit Policy - Logon/Logoff Events A.8.15.4

Logon and logoff events should be audited to track user access patterns and detect unauthorized access.

Severity: HIGH **Expected:** True **Actual:** True

PASS Audit Policy - Policy Changes A.8.15.5

Policy change events should be audited to detect unauthorized modifications to security policies.

Severity: MEDIUM **Expected:** True **Actual:** True

A.8.16 — Monitoring Activities

FAIL Security Event Log Size Adequate A.8.16.1

The Security event log should have a maximum size of at least 1GB to retain sufficient audit history.

Severity: **MEDIUM** Expected: 1024 Actual: 20

■ Remediation Steps

1. Configure via GPO: Computer Configuration > Administrative Templates > Windows Components > Event Log Service > Security > Maximum Log Size 2. Set to at least 1048576 KB (1 GB) 3. Or via PowerShell: `wevtutil sl Security /ms:1073741824` 4. Configure log retention to "Archive when full"

PASS Windows Event Forwarding Configured A.8.16.2

Event forwarding should be configured to centralize security logs from all DCs and critical servers.

Severity: **MEDIUM** Expected: False Actual: Partial

A.8.17 — Clock Synchronization

PASS W32Time Service Running A.8.17.1

The Windows Time service must be running on Domain Controllers for Kerberos authentication and accurate logging.

Severity: **HIGH** Expected: Running Actual: Running

FAIL NTP Source Configured A.8.17.2

The PDC Emulator should be configured to sync with an external NTP source for accurate time.

Severity: **MEDIUM** Expected: True Actual: False

■ Remediation Steps

1. Configure external NTP source on PDC Emulator: `w32tm /config /manualpeerlist:"time.windows.com,0x1" /syncfromflags:manual /reliable:yes /update` 2. Restart the time service: `Restart-Service W32Time` 3. Force sync: `w32tm /resync /force` 4. Verify: `w32tm /query /source`

A.8.18 — Use of Privileged Utility Programs

FAIL PowerShell Script Block Logging Enabled A.8.18.1

PowerShell Script Block Logging should be enabled to capture all PowerShell commands executed on the system.

Severity: **HIGH** Expected: True Actual: False

■ Remediation Steps

1. Configure via GPO: Computer Configuration > Administrative Templates > Windows Components > Windows PowerShell > Turn on PowerShell Script Block Logging 2. Enable the policy 3. Or via registry: `New-Item -Path 'HKLM:\SOFTWARE\Policies\Microsoft\Windows\PowerShell\ScriptBlockLogging' -Force Set-ItemProperty -Path 'HKLM:\SOFTWARE\Policies\Microsoft\Windows\PowerShell\ScriptBlockLogging' -Name 'EnableScriptBlockLogging' -Value 1` 4. Run: `gpupdate /force`

FAIL PowerShell Transcription Enabled [A.8.18.2](#)

PowerShell Transcription should be enabled to create a record of all PowerShell sessions.

Severity: MEDIUM **Expected:** True **Actual:** False

■ Remediation Steps

1. Configure via GPO: Computer Configuration > Administrative Templates > Windows Components > Windows PowerShell > Turn on PowerShell Transcription 2. Set output directory to a secured location 3. Or via registry: New-Item -Path 'HKLM:\SOFTWARE\Policies\Microsoft\Windows\PowerShell\Transcription' -Force Set-ItemProperty -Path 'HKLM:\SOFTWARE\Policies\Microsoft\Windows\PowerShell\Transcription' -Name 'EnableTranscripting' -Value 1 4. Run: gpupdate /force

FAIL PowerShell Module Logging Enabled [A.8.18.3](#)

PowerShell Module Logging should be enabled to track which PowerShell modules are used.

Severity: MEDIUM **Expected:** True **Actual:** False

■ Remediation Steps

1. Configure via GPO: Computer Configuration > Administrative Templates > Windows Components > Windows PowerShell > Turn on Module Logging 2. Add modules to log (use * for all): Module Names: * 3. Run: gpupdate /force

A.8.19 — Installation of Software on Operational Systems

ERROR AppLocker or Software Restriction Policy Defined [A.8.19.1](#)

AppLocker or Software Restriction Policies should be configured to control which applications can run.

Severity: MEDIUM **Expected:** True **Actual:** Error: The term 'Get-GPO' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

FAIL Application Identity Service Running [A.8.19.2](#)

The Application Identity service must be running for AppLocker policies to be enforced.

Severity: LOW **Expected:** Running **Actual:** Stopped

■ Remediation Steps

1. Start the Application Identity service: Start-Service AppIDSvc 2. Set to automatic: Set-Service AppIDSvc -StartupType Automatic 3. Configure via GPO for all DCs and servers

A.8.2 — Privileged Access Rights

ERROR Domain Admins Group Membership Limited [A.8.2.1](#)

The Domain Admins group should have minimal members. Excessive privileged accounts increase the attack surface.

Severity: HIGH **Expected:** 5 **Actual:** Error: The term 'Get-ADGroupMember' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is

correct and try again.

ERROR Enterprise Admins Group Membership Limited A.8.2.2

The Enterprise Admins group should have very few members, ideally only used temporarily for forest-level operations.

Severity: **HIGH** **Expected:** 2 **Actual:** Error: The term 'Get-ADGroupMember' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

ERROR Schema Admins Group Membership Limited A.8.2.3

The Schema Admins group should be empty during normal operations and populated only when schema changes are needed.

Severity: **HIGH** **Expected:** 1 **Actual:** Error: The term 'Get-ADGroupMember' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

ERROR AdminSDHolder Protected Accounts Reviewed A.8.2.4

The AdminCount attribute flags accounts protected by AdminSDHolder. These should be reviewed to ensure no orphaned protected accounts exist.

Severity: **MEDIUM** **Expected:** 15 **Actual:** Error: The term 'Get-ADUser' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

ERROR Built-in Administrator Account Renamed A.8.2.5

The built-in Administrator account (RID 500) should be renamed to reduce targeting by attackers.

Severity: **MEDIUM** **Expected:** True **Actual:** Error: The term 'Get-ADUser' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

A.8.20 — Network Controls

PASS Windows Firewall - Domain Profile Enabled A.8.20.1

The Windows Firewall Domain profile should be enabled on Domain Controllers.

Severity: **HIGH** **Expected:** True **Actual:** True

PASS Windows Firewall - Private Profile Enabled A.8.20.2

The Windows Firewall Private profile should be enabled for additional security layers.

Severity: **MEDIUM** **Expected:** True **Actual:** True

PASS Windows Firewall - Public Profile Enabled A.8.20.3

The Windows Firewall Public profile should be enabled and restrictive.

Severity: **MEDIUM** Expected: True Actual: True

A.8.21 — Security of Network Services

FAIL LDAP Server Signing Required A.8.21.1

LDAP server signing should be required to prevent LDAP relay attacks and ensure data integrity.

Severity: **HIGH** Expected: True Actual: False

■ Remediation Steps

1. Configure via GPO: Computer Configuration > Policies > Windows Settings > Security Settings > Local Policies > Security Options "Domain controller: LDAP server signing requirements" = "Require signing" 2. Or via registry: Set-ItemProperty -Path 'HKLM:\SYSTEM\CurrentControlSet\Services\NTDS\Parameters' -Name 'LDAPServerIntegrity' -Value 2 3. WARNING: Ensure all LDAP clients support signing before enforcing

FAIL SMB Signing Required A.8.21.2

SMB signing should be required on Domain Controllers to prevent man-in-the-middle attacks on SMB communications.

Severity: **HIGH** Expected: True Actual: False

■ Remediation Steps

1. Configure via GPO: Computer Configuration > Windows Settings > Security Settings > Local Policies > Security Options "Microsoft network server: Digitally sign communications (always)" = Enabled 2. Or via registry: Set-ItemProperty -Path 'HKLM:\SYSTEM\CurrentControlSet\Services\LanmanServer\Parameters' -Name 'RequireSecuritySignature' -Value 1 3. Run: gpupdate /force

FAIL LDAP Channel Binding Configured A.8.21.3

LDAP channel binding should be configured to mitigate LDAP relay attacks.

Severity: **HIGH** Expected: True Actual: False

■ Remediation Steps

1. Set LDAP channel binding token requirement: Set-ItemProperty -Path 'HKLM:\SYSTEM\CurrentControlSet\Services\NTDS\Parameters' -Name 'LdapEnforceChannelBinding' -Value 2 2. Values: 0 = Never, 1 = When supported, 2 = Always 3. WARNING: Test with value 1 before enforcing with 2 4. Ensure all clients support channel binding

A.8.22 — Segregation in Networks

ERROR AD Sites Configured A.8.22.1

Active Directory Sites should be configured to represent physical network topology for replication optimization.

Severity: **MEDIUM** Expected: 1 Actual: Error: The term 'Get-ADReplicationSite' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

ERROR AD Subnets Defined A.8.22.2

AD subnets should be defined and associated with sites to ensure clients authenticate against the nearest DC.

Severity: **MEDIUM** **Expected:** 1 **Actual:** Error: The term 'Get-ADReplicationSubnet' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

A.8.23 — Web Filtering

ERROR DNS Filtering or Proxy GPO Configured A.8.23.1

A web filtering solution (DNS-based, proxy, or URL filtering) should be configured via GPO.

Severity: **MEDIUM** **Expected:** True **Actual:** Error: The term 'Get-GPO' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

ERROR DNS Forwarders Configured Securely A.8.23.2

DNS forwarders should point to secure, trusted DNS servers, not arbitrary public DNS.

Severity: **LOW** **Expected:** **Actual:** Error: The term 'Get-DnsServerForwarder' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

A.8.24 — Use of Cryptography

ERROR AES Kerberos Encryption Supported A.8.24.1

Domain Controllers should support AES (128/256) Kerberos encryption types and DES should be disabled.

Severity: **HIGH** **Expected:** True **Actual:** Error: The term 'Get-ADDomainController' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

PASS TLS 1.2 Enabled A.8.24.2

TLS 1.2 should be enabled on Domain Controllers for secure communications.

Severity: **HIGH** **Expected:** True **Actual:** True

PASS SSL 3.0 Disabled A.8.24.3

SSL 3.0 should be disabled as it has known vulnerabilities (POODLE attack).

Severity: **HIGH** **Expected:** False **Actual:** NotConfigured

A.8.25 — Secure Development Lifecycle

PASS AD Certificate Services Templates Secured A.8.25.1

If AD Certificate Services (ADCS) is deployed, certificate templates should have restricted enrollment permissions.

Severity: MEDIUM **Expected:** Actual: ADCS not installed

A.8.26 — Application Security Requirements

ERROR Service Accounts Use Managed Service Accounts A.8.26.1

Applications should use Group Managed Service Accounts (gMSA) instead of regular user accounts for automatic password management.

Severity: MEDIUM **Expected:** 1 **Actual:** Error: The term 'Get-ADServiceAccount' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

ERROR Service Account Passwords Not Set to Never Expire A.8.26.2

Service accounts with 'Password Never Expires' should be minimized or use gMSA instead.

Severity: MEDIUM **Expected:** 10 **Actual:** Error: The term 'Get-ADUser' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

A.8.27 — Secure System Architecture and Engineering Principles

ERROR Domain Functional Level Current A.8.27.1

The domain functional level should be at Windows Server 2016 or higher to access the latest security features.

Severity: MEDIUM **Expected:** Windows2008Domain **Actual:** Error: The term 'Get-ADDomain' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

ERROR Forest Functional Level Current A.8.27.2

The forest functional level should be at Windows Server 2016 or higher.

Severity: MEDIUM **Expected:** Windows2008Forest **Actual:** Error: The term 'Get-ADForest' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

ERROR Trust Relationships Reviewed A.8.27.3

AD trust relationships should be reviewed to ensure no unintended external trusts exist.

Severity: HIGH **Expected:** Actual: Error: The term 'Get-ADTrust' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

A.8.28 — Secure Coding

PASS PowerShell Execution Policy Restricted A.8.28.1

PowerShell execution policy should require signed scripts or be restricted to prevent unauthorized script execution.

Severity: MEDIUM **Expected:** Unrestricted **Actual:** Restricted

ERROR PowerShell Constrained Language Mode Available A.8.28.2

PowerShell Constrained Language Mode should be available for non-admin users to limit attack surface.

Severity: LOW **Expected:** True **Actual:** Error: The term 'Get-GPO' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

A.8.29 — Security Testing in Development and Acceptance

ERROR No Inactive User Accounts (90+ Days) A.8.29.1

User accounts that have not logged in for 90+ days should be disabled or removed.

Severity: MEDIUM **Expected:** 10 **Actual:** Error: The term 'Get-ADUser' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

ERROR No Stale Computer Accounts (90+ Days) A.8.29.2

Computer accounts that have not authenticated in 90+ days may indicate decommissioned machines and should be cleaned up.

Severity: LOW **Expected:** 20 **Actual:** Error: The term 'Get-ADComputer' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

ERROR Excessive Group Nesting Detected A.8.29.3

Deeply nested group membership (groups within groups) can lead to unintended privilege escalation and should be minimized.

Severity: LOW **Expected:** 5 **Actual:** Error: The term 'Get-ADGroup' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

A.8.3 — Information Access Restriction

ERROR Organizational Units (OU) Structure Exists A.8.3.1

AD should have a structured OU hierarchy to enable proper access control delegation and Group Policy application.

Severity: MEDIUM **Expected:** 3 **Actual:** Error: The term 'Get-ADOrganizationalUnit' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

ERROR OU Delegation Properly Configured A.8.3.2

Administrative delegation should be configured at the OU level to enforce principle of least privilege.

Severity: MEDIUM **Expected:** True **Actual:** Error: The term 'Get-ADOrganizationalUnit' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

A.8.30 — Outsourced Development

ERROR External Trust Relationships Reviewed A.8.30.1

External trust relationships allow authentication across domains and should be carefully reviewed.

Severity: HIGH **Expected:** Actual: Error: The term 'Get-ADTrust' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

ERROR Foreign Security Principals Reviewed A.8.30.2

Foreign Security Principals (accounts from trusted domains) should be reviewed and limited.

Severity: MEDIUM **Expected:** 20 **Actual:** Error: The term 'Get-ADDomain' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

A.8.31 — Separation of Development, Test and Production Environments

ERROR Separate OUs for Different Environments A.8.31.1

Separate Organizational Units should exist for development, test, and production environments.

Severity: MEDIUM **Expected:** None found **Actual:** Error: The term 'Get-ADOrganizationalUnit' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

ERROR Dev/Test Groups Separate from Production A.8.31.2

Security groups for development and testing should be separate from production groups.

Severity: LOW **Expected:** True **Actual:** Error: The term 'Get-ADGroup' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

A.8.32 — Change Management

ERROR GPO Versioning Active A.8.32.1

Group Policy Objects should be versioned to track changes and support rollback.

Severity: **MEDIUM** **Expected:** **Actual:** Error: The term 'Get-GPO' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

ERROR AD Change Notifications Configured [A.8.32.2](#)

AD replication change notifications should be configured to promptly propagate changes.

Severity: **LOW** **Expected:** **Actual:** Error: The term 'Get-ADReplicationSiteLink' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

A.8.33 — Test Information

ERROR No Test Accounts in Production AD [A.8.33.1](#)

Test or temporary accounts should not exist in the production Active Directory environment.

Severity: **MEDIUM** **Expected:** 0 **Actual:** Error: The term 'Get-ADUser' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

ERROR No Users with Empty Passwords [A.8.33.2](#)

No enabled user accounts should have empty (blank) passwords.

Severity: **HIGH** **Expected:** 0 **Actual:** Error: The term 'Get-ADUser' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

A.8.34 — Protection of Information Systems During Audit Testing

ERROR Audit/Compliance Accounts Identifiable [A.8.34.1](#)

Accounts used for audit and compliance testing should be clearly identifiable and follow naming conventions.

Severity: **LOW** **Expected:** **Actual:** Error: The term 'Get-ADUser' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

ERROR No Temporarily Elevated Accounts Left Active [A.8.34.2](#)

Temporary privileged access should be revoked after audit activities. No accounts should be lingering in admin groups from past audits.

Severity: **MEDIUM** **Expected:** 0 **Actual:** Error: The term 'Get-ADGroupMember' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

A.8.4 — Access to Source Code

ERROR Developer Groups Exist for Access Control A.8.4.1

Dedicated security groups should exist for managing access to source code repositories and development resources.

Severity: **MEDIUM** **Expected:** True **Actual:** Error: The term 'Get-ADGroup' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

ERROR Service Accounts for Source Control Identified A.8.4.2

Service accounts used for source code management (Git, SVN, etc.) should be properly identified and managed in AD.

Severity: **LOW** **Expected:** 0 **Actual:** Error: The term 'Get-ADUser' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

A.8.5 — Secure Authentication

ERROR Minimum Password Length >= 12 A.8.5.1

The domain password policy should enforce a minimum password length of at least 12 characters.

Severity: **HIGH** **Expected:** 12 **Actual:** Error: The term 'Get-ADDefaultDomainPasswordPolicy' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

ERROR Password Complexity Enabled A.8.5.2

Password complexity requirements should be enabled to enforce strong passwords containing uppercase, lowercase, digits, and special characters.

Severity: **HIGH** **Expected:** True **Actual:** Error: The term 'Get-ADDefaultDomainPasswordPolicy' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

ERROR Maximum Password Age <= 90 Days A.8.5.3

Passwords should expire within 90 days to limit exposure from compromised credentials.

Severity: **MEDIUM** **Expected:** 90 **Actual:** Error: The term 'Get-ADDefaultDomainPasswordPolicy' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

ERROR Password History >= 12 A.8.5.4

Password history should remember at least 12 previous passwords to prevent password reuse.

Severity: **MEDIUM** **Expected:** 12 **Actual:** Error: The term 'Get-ADDefaultDomainPasswordPolicy' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was

included, verify that the path is correct and try again.

ERROR Account Lockout Threshold Configured A.8.5.5

Account lockout threshold should be set to prevent brute-force attacks. Recommended: 5 or fewer invalid attempts.

Severity: **HIGH** **Expected:** 0 **Actual:** Error: The term 'Get-ADDefaultDomainPasswordPolicy' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

ERROR Account Lockout Duration >= 30 Minutes A.8.5.6

Locked accounts should remain locked for at least 30 minutes to slow down brute-force attacks.

Severity: **MEDIUM** **Expected:** 30 **Actual:** Error: The term 'Get-ADDefaultDomainPasswordPolicy' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

ERROR Kerberos Ticket Max Lifetime <= 10 Hours A.8.5.7

Kerberos TGT lifetime should be limited to reduce the window of attack if tickets are compromised.

Severity: **MEDIUM** **Expected:** **Actual:** Error: The term 'Get-ADDefaultDomainPasswordPolicy' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

ERROR Reversible Encryption Disabled A.8.5.8

Storing passwords using reversible encryption should be disabled as it is equivalent to storing plaintext passwords.

Severity: **HIGH** **Expected:** False **Actual:** Error: The term 'Get-ADDefaultDomainPasswordPolicy' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

A.8.6 — Capacity Management

PASS Domain Controller Disk Space Adequate A.8.6.1

Domain Controllers should have sufficient free disk space on the system drive to ensure AD operations are not disrupted.

Severity: **HIGH** **Expected:** 10 **Actual:** 43.19

ERROR AD Replication Healthy A.8.6.2

Active Directory replication between Domain Controllers should be functioning without errors.

Severity: **HIGH** **Expected:** True **Actual:** Error: The term 'repadmin' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

A.8.7 — Protection Against Malware

PASS Windows Defender Antivirus Enabled A.8.7.1

Windows Defender or an equivalent antivirus solution should be running on the Domain Controller.

Severity: **HIGH** Expected: True Actual: True

PASS Antivirus Definitions Up-to-Date A.8.7.2

Antivirus signature definitions should be up-to-date (within the last 7 days) to protect against latest threats.

Severity: **HIGH** Expected: True Actual: True

A.8.8 — Management of Technical Vulnerabilities

PASS SMBv1 Protocol Disabled A.8.8.1

SMBv1 is a legacy protocol with known vulnerabilities (WannaCry, EternalBlue). It should be disabled.

Severity: **HIGH** Expected: True Actual: True

PASS Windows Updates Recently Installed A.8.8.2

Windows updates should be installed regularly. The last update should be within the past 30 days.

Severity: **HIGH** Expected: True Actual: True

FAIL LLMNR Disabled A.8.8.3

Link-Local Multicast Name Resolution (LLMNR) should be disabled to prevent name resolution poisoning attacks.

Severity: **MEDIUM** Expected: True Actual: False

■ Remediation Steps

```
1. Disable via GPO: Computer Configuration > Administrative Templates > Network > DNS Client Set "Turn off multicast name resolution" to Enabled
2. Or via registry: Set-ItemProperty -Path 'HKLM:\SOFTWARE\Policies\Microsoft\Windows NT\DNSClient' -Name 'EnableMulticast' -Value 0
3. Run: gpupdate /force
```

A.8.9 — Configuration Management

ERROR Group Policies Defined A.8.9.1

Multiple Group Policies should be defined to manage system configurations across the domain.

Severity: **MEDIUM** Expected: 3 Actual: Error: The term 'Get-GPO' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.

ERROR GPOs Linked to OUs A.8.9.2

Group Policies should be linked to Organizational Units to enforce configuration standards.

Severity: MEDIUM **Expected:** True **Actual:** Error: The term 'Get-GPO' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.